



Institut Universitaire de Technologie de Nice - Côte d'Azur
Département **Réseaux & Télécommunications**

Mohamed Droussi
Johan Abdallah

T.P de Cyber n° R4.Cyber.09 -01

“Sécurité des réseaux LAN”

TP : Vulnérabilités de Couche 2 - VLAN, DHCP et ARP

- **Intégration des équipements réseaux dans l'architecture**
- **Sécurisation de base sur routeur et switch**
- **Attaque (n°1) VLAN Hopping (Switch Spoofing)**
- **Attaque (n°2) DHCP Spoofing**
- **Attaque (n°3) ARP Spoofing (Empoisonnement ARP)**



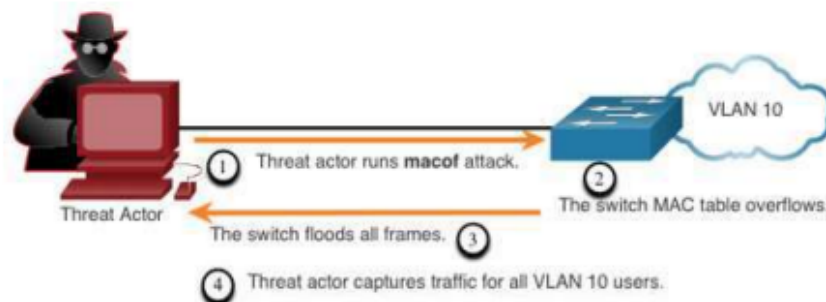
I - Préambule

Malgré la robustesse de nos murailles de pierre (pare-feux de périmètre), les cours intérieures de nos châteaux (Couche 2 du modèle OSI) sont souvent négligées, ce qui les rend extrêmement vulnérables aux trahisons et aux attaques internes. Les postes de garde (switches) s'appuient sur des règles d'accueil par défaut (Plug-and-Play) qui privilégient la libre circulation des marchands au détriment de la sécurité du royaume. Ce TP vous apprendra à repousser les ruses des mercenaires (attaques réseau de couche 2) et à fortifier vos équipements face à ces menaces.

I.1 - Rappels de cours : Attaque par Déni de Service (MAC Flooding)

Le MAC Flooding est une attaque visant à saturer la table CAM (Content Addressable Memory) d'un commutateur. Le switch, ne pouvant plus stocker de nouvelles adresses MAC, bascule en mode fail-open et se comporte comme un simple Hub, diffusant tout le trafic sur tous ses ports. Cela permet à l'attaquant d'écouter le trafic et provoque un fort ralentissement du réseau.

- Protection : Activation du "port-security" sur les commutateurs.



I.2 - Rappels de cours: VLAN Hopping (Attaque par Switch Spoofing)

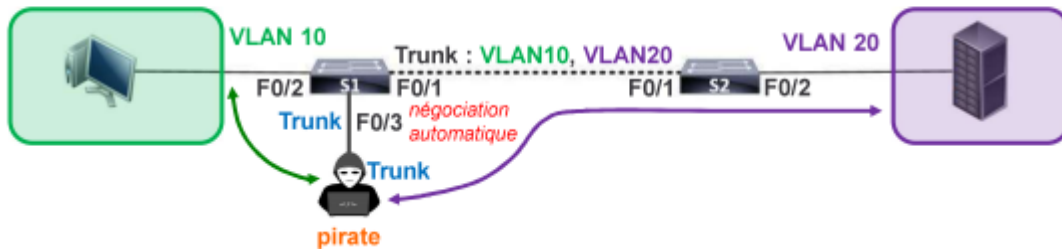
Le saut de VLAN (VLAN Hopping) est une attaque permettant à une machine d'accéder à du trafic appartenant à des VLANs auxquels elle n'est pas censée avoir accès. Les commutateurs Cisco utilisent le protocole **DTP (Dynamic Trunking Protocol)** pour négocier automatiquement la création de liens Trunk (des liens transportant le trafic de plusieurs VLANs avec des balises 802.1Q) entre deux équipements. Par défaut, de nombreux ports sont configurés en mode dynamic auto ou dynamic desirable.

- **L'attaque** : L'attaquant envoie des trames DTP falsifiées au commutateur pour se faire passer pour un autre switch. Si le commutateur accepte la négociation, le port de l'attaquant devient un port Trunk.

- **Conséquences :** L'attaquant reçoit le trafic diffusé sur tous les VLANs autorisés sur le Trunk et peut injecter du trafic dans n'importe quel VLAN en ajoutant manuellement le tag 802.1Q correspondant à ses paquets.
- **Protection :** Désactiver la négociation DTP (switchport nonegotiate) et forcer les ports utilisateurs en mode accès statique (switchport mode access).

Objectif de l'usurpation de VLAN :

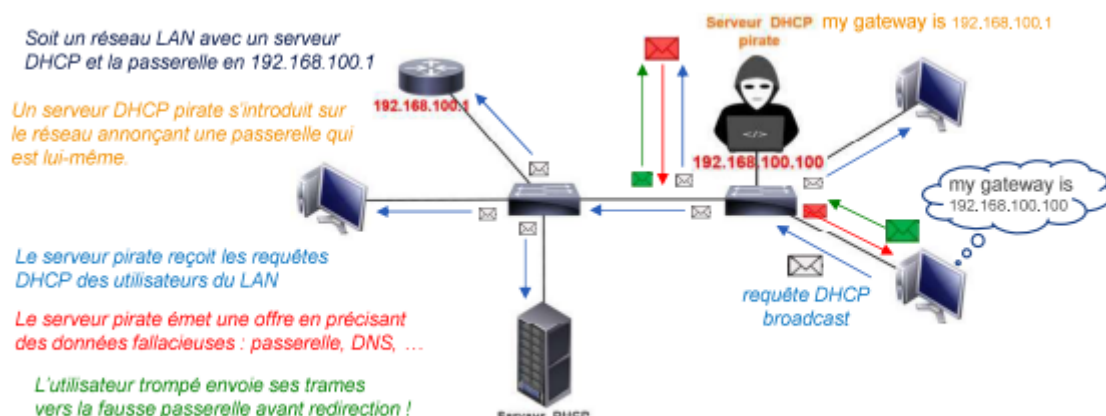
- *établir une liaison « trunk » avec un autre commutateur*
- *recupérer le trafic étiqueté du réseau*



I.3 - Rappels de cours : DHCP Spoofing

L'attaque DHCP Spoofing consiste à installer un faux serveur DHCP sur le réseau, capable d'attribuer des configurations frauduleuses aux clients. Lorsqu'un client rejoint le réseau, il diffuse une requête DHCP Discover.

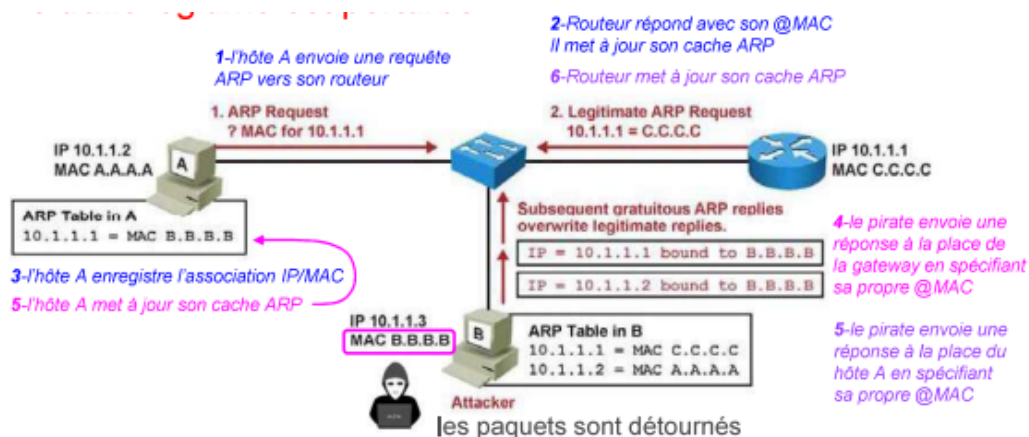
- **L'attaque :** L'attaquant, disposant d'un serveur DHCP très réactif (souvent sous Linux avec dnsmasq), répond avec un DHCP Offer plus rapidement que le serveur légitime du réseau.
- **Conséquences :** L'attaquant peut fournir sa propre adresse IP en tant que passerelle par défaut (Gateway) et serveur DNS. Cela lui permet d'intercepter tout le trafic sortant de la victime vers Internet et de réaliser des attaques de type homme du milieu (MITM).
- **Protection :** Activation du DHCP Snooping pour définir des ports de "confiance" (reliés aux vrais serveurs DHCP) et des ports non fiables (où les messages DHCP Offer seront bloqués).



I.4 - Rappels de cours : ARP Spoofing (Empoisonnement ARP)

Le protocole ARP (Address Resolution Protocol) permet d'associer une adresse IP logique à une adresse MAC physique. Ce protocole ne possède aucun mécanisme d'authentification.

- **L'attaque :** L'attaquant envoie en continu des réponses ARP non sollicitées (Gratuitous ARP) à la victime et à la passerelle. Il indique à la victime "L'adresse IP de la passerelle correspond à mon adresse MAC" et à la passerelle "L'adresse IP de la victime correspond à mon adresse MAC".
- **Conséquences :** Les tables ARP des victimes sont corrompues (empoisonnées). Le trafic entre la victime et la passerelle transite physiquement par la machine de l'attaquant, permettant une écoute clandestine totale.
- **Protection :** Mise en place du **Dynamic ARP Inspection (DAI)**, qui s'appuie sur la base de données du DHCP Snooping pour vérifier que l'adresse IP annoncée dans le paquet ARP correspond bien à l'adresse MAC et au port physique légitimes.



I.4 - Rappels de configuration

Pour bâtir nos défenses, nous utiliserons les incantations de base de l'IOS Cisco :

- Création des quartiers : `vlan [ID], name [Nom]`
- Assignation d'un garde à un quartier : `switchport mode access, switchport access vlan [ID]`
- Création d'un pont-levis (Trunk) : `switchport mode trunk`
- Désactivation des négociations douteuses (Désactiver DTP) : `switchport nonegotiate`

Les sorts de protection (commandes) à maîtriser :

- `switchport port-security` : Pour limiter le nombre de visages par porte.
- `switchport nonegotiate` : Pour briser les négociations de pont-levis.
- `ip dhcp snooping` : Pour filtrer les annonces de faux intendants.
- `ip arp inspection` : Pour vérifier la légitimité des parchemins ARP.

I.4 - Quelques éléments complémentaires

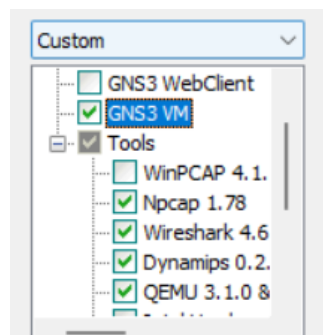
Gardez en tête que l'attaquant utilisera une machine redoutable nommée **Kali Linux**. Les outils de siège incluront *Yersinia* (pour les attaques protocolaires) et *Ettercap* ou *arpspoof* (pour l'empoisonnement des registres).

I.bis.1 - Installation de GNS3

Pour simuler notre royaume, nous utiliserons le simulateur GNS3. Il permet de modéliser des architectures complexes de manière virtuelle. Pour héberger vos machines virtuelles (Kali, Debian) et assurer leur liaison avec le royaume GNS3, l'utilisation de VMWare 17.5.2 est indispensable

L'environnement de simulation GNS3 (Graphical Network Simulator-3) sera donc notre outil principal pour ce TP. Il s'agit d'une puissante plateforme d'émulation réseau qui permet de modéliser, configurer et tester des architectures complexes de manière totalement virtuelle. Grâce à GNS3, vous aurez la possibilité d'exécuter de véritables systèmes d'exploitation d'équipements réseau (comme le Cisco IOS) et de les interconnecter avec des machines virtuelles classiques (Debian, Kali Linux, etc.).

- **Téléchargement** : Récupérez l'installateur correspondant à votre système d'exploitation directement sur le site officiel de l'éditeur à cette adresse :
<https://www.gns3.com/software/download>



- Outils à installer lors de l'installation :

I.bis.2 - Installation de VMWare 17.5.2

Pour héberger les machines virtuelles (Kali, Debian) et assurer leur liaison avec GNS3, l'utilisation d'un hyperviseur tel que VMware Workstation Player est indispensable. Cet outil garantit une isolation parfaite de vos équipements virtuels vis-à-vis de votre système d'exploitation hôte, évitant ainsi de perturber la configuration de votre ordinateur personnel lors des manipulations d'attaques.

Sa capacité à faire tourner plusieurs systèmes d'exploitation simultanément permet de recréer les conditions exactes d'une infrastructure réseau professionnelle. Dans notre laboratoire,

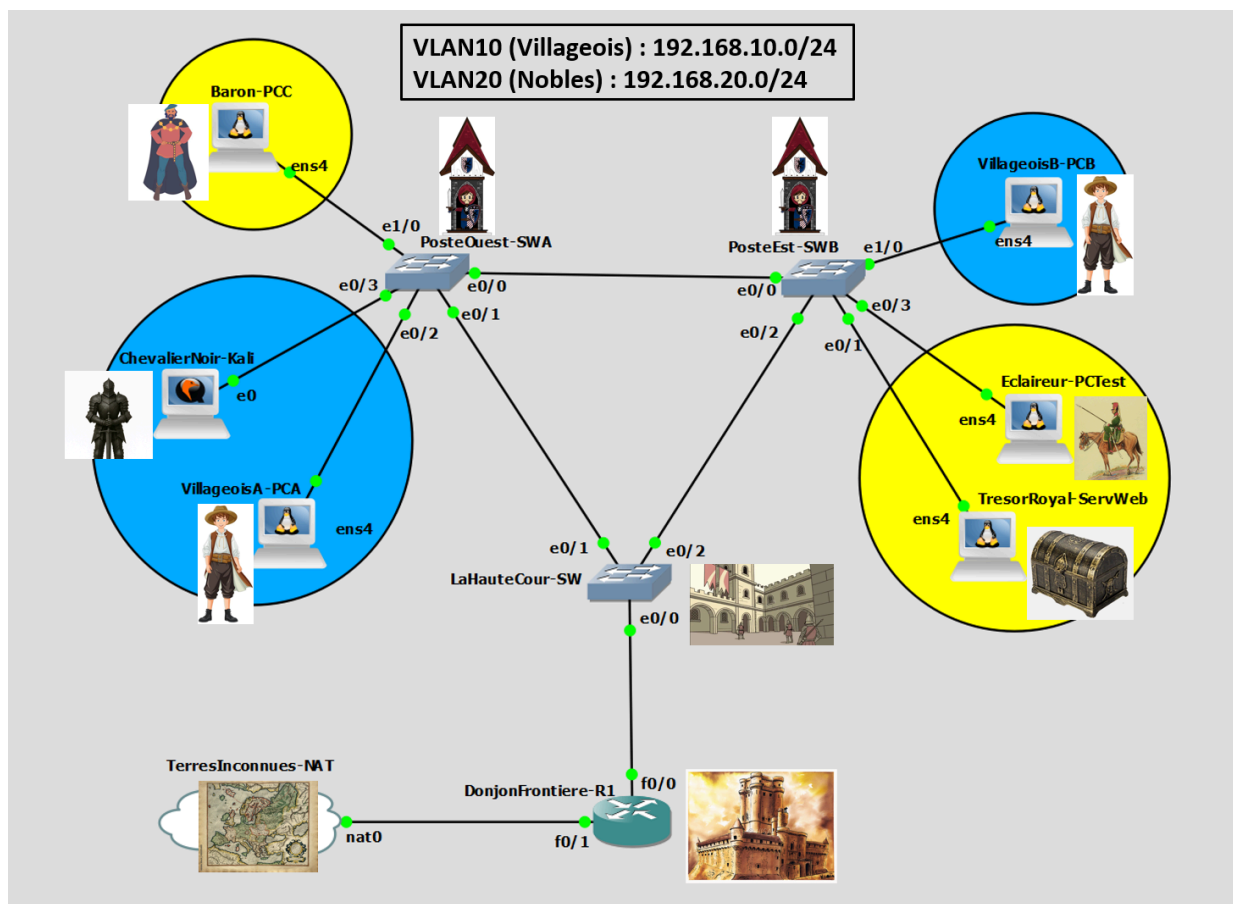
chaque machine virtuelle simulera un acteur distinct (la machine attaquante et la victime), communiquant en temps réel avec les équipements actifs émulés par GNS3.

- Pour l'installer, allez sur le site ci-dessous, puis suivez ces étapes:
<https://www.clubic.com/telecharger-fiche121950-vmware-workstation.html>

II. Préparation

Cette partie vise à mettre en œuvre l'environnement GNS3 conformément à la **topologie fournie**. C'est ici que nous posons les fondations matérielles du château.

II.1 - Topologie Globale



La structure se compose comme suit :

- Le donjon (Routeur R1) : Passerelle vers l'extérieur et Serveur DHCP.
- La Haute Cour : L'équipement central qui relie toutes les entités.
- Poste de Garde Ouest (PosteOuest-SWA) : Zone de danger. Connecte le Villageois A (Debian) et le Chevalier Noir (Kali) dans une zone villageoise (**VLAN10**). Contient aussi une zone de noblesse (**VLAN20**)
- Poste de Garde Est (PosteEst-SWB) : Contient une zone de noblesse (**VLAN20**) avec le Trésor Royal (Serveur Web) et l'éclaireur (PCTest). Une zone villageoise avec PCB.

II.2 - Configurer les paramètres IP et le Routage

Avant que la bataille ne commence, vous devez définir les limites du quartier et les chemins que prendront les messagers. Le Routeur R1 fera office de Grand Scribe, distribuant les adresses IP et guidant les troupes entre les VLANs.

Configurez les sous-interfaces pour permettre le routage inter-quartiers (routage inter-vlan) sur le routeur.

Configurez le nat inside et outside sur le routeur.

Question : Quelles commandes avez-vous utilisé pour permettre le routage inter-vlan ?
Question : Quelles commandes avez-vous utilisé pour permettre le nat ?

Note : Utilisez l'encapsulation dot1Q pour que le routeur comprenne les blasons des différents VLANs.

Réponse :

```
R1(config)# interface Fa0/0
R1(config-subif)# no sh
R1(config)# interface Fa0/0.10
R1(config-subif)# encapsulation dot1Q 10
R1(config-subif)# ip address 192.168.10.254 255.255.255.0
R1(config-subif)# exit
R1(config)# interface Fa0/0.20
R1(config-subif)# encapsulation dot1Q 20
R1(config-subif)# ip address 192.168.20.254 255.255.255.0
```

Réponse :

```
R1(config)# interface Fa0/0
R1(config-subif)# ip nat inside
R1(config)# interface Fa0/1
R1(config-subif)# ip nat outside
```


Configurez deux pools DHCP sur le routeur R1 en respectant le cahier des charges suivant :

- **Réseau à distribuer** : 192.168.10.0 / 24 **ET** 192.168.20.0 / 24
- **,Passerelle par défaut (Default Router)** : 192.168.10.254 **ET** 192.168.20.254
- **Serveur DNS** : 8.8.8.8 (Google)
- **Contrainte de sécurité** : Vous devez impérativement exclure les adresses IP du routeur pour qu'elle ne soit pas distribuée à un poste.

Une fois la configuration terminée sur R1, basculez sur vos machines virtuelles (Kali et Debian) pour récupérer dynamiquement vos adresses IP.

Question : Créez les pools DHCP royaux pour chaque VLAN afin que les émissaires reçoivent automatiquement leurs adresses IP.

Question : Quelle commande Cisco avez-vous utilisée pour exclure l'adresse du routeur, et que se passerait-il si vous oubliiez de le faire ?

Question : Quelle commande avez-vous tapée sur le routeur R1 pour vérifier qu'il a bien distribué les adresses IP à la Kali et à la Debian ? (Fournissez une capture d'écran du résultat).

Question : Sur les machines Linux (Debian et Kali), quelle commande utilisez-vous dans le terminal pour forcer la machine à interroger le serveur DHCP ?

Réponses Version Prof :

Réponse :

```
R1(config)# ip dhcp pool POOL_VILLAGEOIS
R1(dhcp-config)# network 192.168.10.0 255.255.255.0
R1(dhcp-config)# default-router 192.168.10.254
R1(dhcp-config)# dns-server 8.8.8.8
R1(config)# ip dhcp pool POOL_NOBLES
R1(dhcp-config)# network 192.168.20.0 255.255.255.0
R1(dhcp-config)# default-router 192.168.20.254
R1(dhcp-config)# dns-server 8.8.8.8
```

Réponse : ip dhcp excluded-address 192.168.10.254

Réponse : show ip dhcp binding

Réponse : sudo dhclient eth0 (mettre sudo que si on est pas en root)

II.3 - Configuration de base du Switch

Le Switch est le cœur de votre forteresse. Pour l'instant, nous allons le configurer pour qu'il soit fonctionnel, mais nous allons laisser les options par défaut qui le rendent vulnérable.

Sur le Switch, vous devez :

- Créer les quartiers **VLAN10 (nommé Villageois)** et **VLAN20 (nommé Nobles)**
- Configurer les liens trunks (**switchport mode trunk**)
- Placer les villageois et le chevalier noir dans le VLAN10
- Placer le Trésor Royal, l'éclaireur, et le Baron dans le VLAN20

Question : Quelles commandes avez-vous utilisé pour créer les quartiers (VLANs) ?

Question : Quelles commandes avez-vous utilisé pour configurer les liens trunks ?

Question : Quelles commandes avez-vous utilisé pour assigner les ports aux VLANs respectifs ?

Question : Testez la connectivité du VLAN10 en faisant un ping du VillageoisA (PCA) au VillageoisB (PCB)

Question : Testez la connectivité du VLAN20 en faisant un ping du Baron (PCC) au Trésor Royal (ServWeb)

Note : Pour l'instant, ne configurez AUCUNE sécurité avancée. Le château doit être fonctionnel mais vulnérable.

Vous devez être capable de ping l'entièreté des équipements à partir d'un poste (ex: PCA doit pouvoir ping PCTest)

→ Prince Abdallah et Sir Droussi devront valider la connectivité afin de poursuivre le TP.

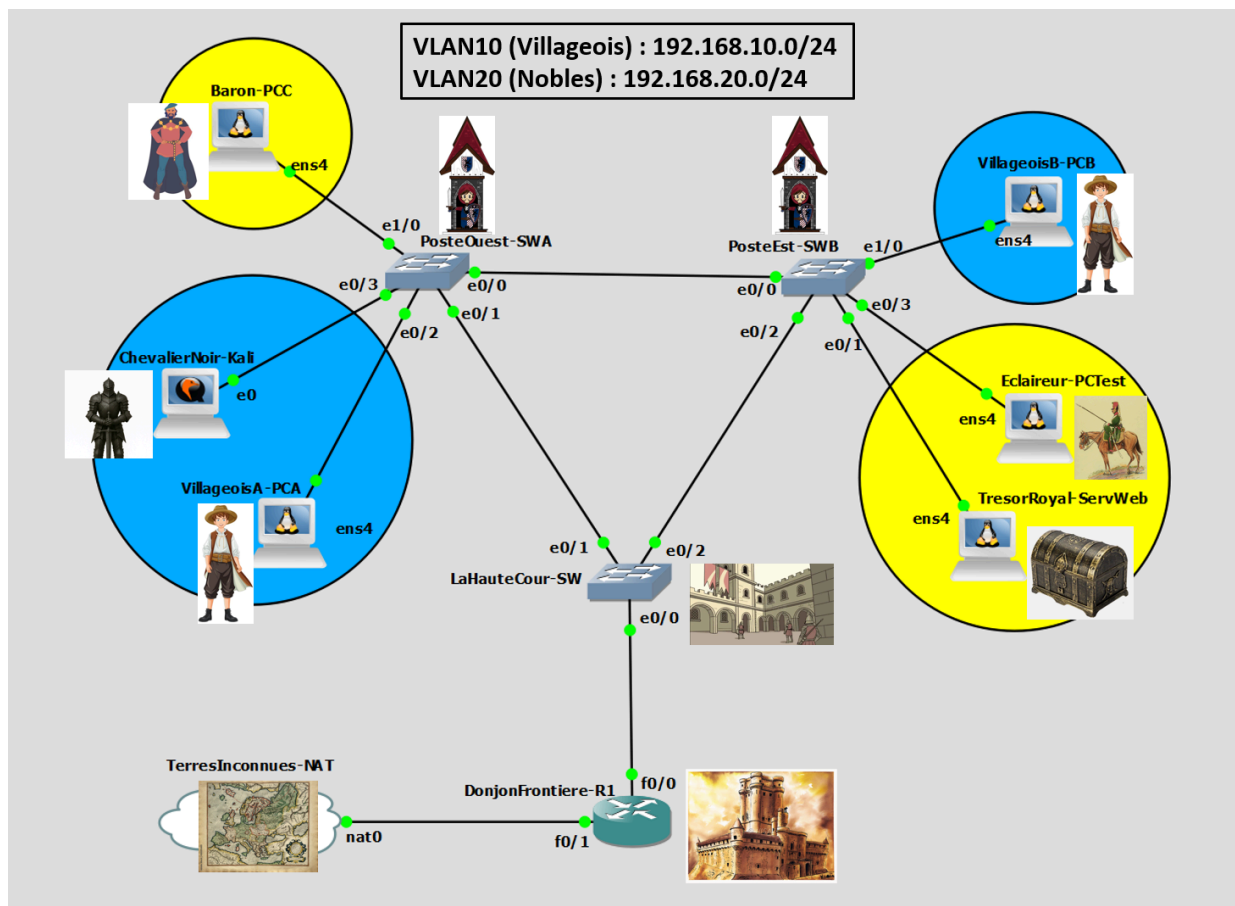
III. Manipulation

L'objectif de cette manipulation est de mettre en place l'infrastructure (premier temps), de subir les assauts du Chevalier Noir (second temps), puis de fortifier définitivement le château (dernier temps).

III.1 - Mise en place de la topologie

Reproduire la topologie et les configurations de la préparation.

Démarrez tous les équipements sous GNS3. Vérifiez que la machine Debian reçoit bien son adresse IP via DHCP de la part du Routeur. Vérifiez que la machine Kali est également connectée. Testez les communications avec une commande ping entre les nobles (Debian) et le Donjon (Routeur). Tout doit fonctionner en temps de paix.



III.2 - L'édification des Remparts (Sécurisation de base)

Avant d'ouvrir les portes du royaume, le Maître Architecte doit s'assurer que l'accès au Donjon (Routeur) et au Grand Carrefour (Switch) est protégé par des sceaux magiques et des gardes d'élite.

L'objectif est d'interdire tout accès non autorisé aux postes de commandement. Pour ce faire, vous devez implémenter les mesures de sécurité apprises lors de vos premières années d'apprentissage à l'académie.

Manipulation 1 : Le Blason et l'Avertissement (Bannière)

Tout voyageur se présentant aux portes doit savoir qu'il entre dans un domaine protégé. Affichez un message d'avertissement dissuasif.

Configurer un banner motd pour prévenir que tout accès non autorisé sera puni par la loi du Royaume.

Question : Quelle commande avez-vous utilisé pour configurer un banner motd ?

Manipulation 2 : Le registre des Portes (Description)

Un bon intendant sait exactement à quoi sert chaque ouverture dans la muraille.

Ajoutez une description sur chaque interface active (vers les émissaires, vers le Chevalier Noir et entre les équipements).

Question : Quelle commande avez-vous utilisé pour ajouter une description sur chaque interface active ?

Manipulation 3 : Le messenger Crypté (Activation de SSHv2)

Les ordres envoyés à distance ne doivent pas être interceptés par des espions sur la route. Le protocole Telnet (en clair) est banni au profit du parchemin scellé (SSHv2).

Définir un nom de domaine, générer une clé RSA de 2048 bits et forcer l'utilisation de SSH sur les lignes de communication. + Création d'un compte dans la base de données locale de l'équipement pour permettre la connexion SSH.

Question : Quelle commande avez-vous utilisé pour configurer le SSH ?

Manipulation 4 : Les mots de Passe

L'accès physique (Console) et l'accès au grimoire des commandes (Mode Privilégié) doivent être protégés par des formules secrètes complexes et cryptées dans la mémoire de l'équipement.

Configurer un enable secret et un mot de passe de console, puis créer un compte utilisateur local pour les administrateurs du château.

Question : Quelle commande avez-vous utilisé pour sécuriser l'accès console et au mode privilégié ?

Note : Une fois ces mesures appliquées, testez la connexion depuis la machine Debian (l'émissaire) en utilisant la commande `ssh archimage@[IP_du_Switch]`. Si le sceau est valide, vous pourrez commander l'équipement à distance en toute sécurité.

Réponse :

Configuration de la bannière

```
(conf)#banner motd #Message de bienvenue#
```

Ajout de descriptions sur les ports

```
(conf-if)#interface fastEthernet 0/0
```

```
(conf-if)#description Connexion vers le switch principal
```

Activation du service SSHv2 avec une clé RSA de 2048 bits

```
(conf)#ip domain-name monreseau.com
```

```
(conf)#crypto key generate rsa usage-keys label SSH_KEY modulus 2048
```

Connexion à distance uniquement via SSH

```
(conf)#line vty 0 4
```

```
(conf-line)#transport input ssh
```

Configuration des mots de passe forts pour la console et le mode privilégié

```
(conf)#enable secret mdp_R409
```

```
(conf-line)#line con 0
```

```
(conf-line)#password mdp_R409_console
```

```
(conf-line)#login
```

Création d'un compte pour SSH dans la base de données locale

```
(conf)#username utilisateur privilege 15 secret mdp_user_R409
```

III.3 - La Brèche dans la Muraille : Le VLAN Hopping (saut de VLAN)

L'objectif de cette phase est de démontrer comment un espion peut s'affranchir des barrières magiques (VLANs) pour s'introduire dans les quartiers réservés sans passer par le Donjon (Routeur) dans le but d'espionner le trafic.

III.3.1 - État des lieux

Pour que l'assaut réussisse, nous exploitons une faille de courtoisie des gardes. Par défaut, les ports des switches Cisco utilisent le protocole DTP (Dynamic Trunking Protocol) pour négocier leur état.

Afin de faciliter l'agrandissement du château, l'intendant a laissé les portes en mode négociation. Pour simuler cette vulnérabilité, nous allons configurer le port du Chevalier Noir pour qu'il annonce activement sa volonté de devenir un pont-levis (Trunk).



Manipulation : Sur le PosteOuest-SWA, configurez l'interface de la Kali (Eth0/3) en mode desirable

```
PosteOuest-SWA(config)# interface Ethernet0/3
PosteOuest-SWA(config-if)# switchport mode dynamic desirable
```

III.3.2 - Attaque n°1 : Le Switch Spoofing (Usurpation de Switch)

Manipulation : Analyser les paquets DTP

Sur la Kali, lancez l'outil de siège en mode interactif :

```
sudo yersinia -I
```

Appuyez sur F5 pour sélectionner le menu DTP. Attendez jusqu'à voir s'afficher un élément.

Question : à quoi correspond ce que vous voyez dans cette fenêtre ?

Réponse : On observe les annonces DTP du switch. Le port est en mode "Desirable", ce qui signifie qu'il attend qu'un voisin lui propose de monter un Trunk pour accepter.

Manipulation : Forcer le Trunking

Appuyez sur X pour ouvrir le menu des attaques, puis choisissez "1: enabling trunking".

Question : Qu'est-ce qui s'est rajouté dans la fenêtre Yersinia ?

Réponse : Une nouvelle ligne de statut confirme que le lien est passé en mode **Trunking**. La Kali a convaincu le switch qu'elle était elle-même un commutateur.

Manipulation : Vérification dans le switch

Sur le Switch Ouest, vérifiez l'état des trunks (commande à taper en mode privilège).

Question : Quelle commande avez vous utilisé pour vérifier l'état des trunks ?

Question : Quelle interface est apparue dans la liste des trunks

Réponse : `show interfaces trunk`

Réponse : Une nouvelle ligne de statut confirme que le lien est passé en mode **Trunking**. La Kali a "convaincu" le switch qu'elle était elle-même un commutateur.

Manipulation : Infiltration dans le VLAN20

Le chevalier Noir peut désormais étiqueter ses propres messages avec le blason du VLAN 20. Sur la machine Kali, tapez ces commandes dans un terminal :

```
sudo vconfig add eth0 20  
sudo ip link set eth0.20 up  
sudo dhclient eth0.20
```

Vérifiez votre adresse IP à l'aide d'un `ip a`.

Question : Avez vous obtenu une ip en 192.168.20.x ?

Question : Si oui, pouvez-vous ping le ServWeb dans le VLAN20 ?

Réponse : Oui

Réponse : On ne peut pas ping le ServWeb

Manipulation : Interception des messages de la Noblesse

Avant de commencer cette manipulation, vous devez faire en sorte que le Baron (VLAN20) puisse accéder au Trésor Royal (VLAN20). Effectuez les manipulations nécessaires pour que PCc puisse ping ServWeb.

Une fois que les deux entités peuvent communiquer, nous allons lancer une capture Wireshark sur la Kali. Démarrez Wireshark sur Kali Linux :
en mode root dans la console : [wireshark](#)

Sélectionnez eth0 (et non eth0.20) car on souhaite voir tout ce qui arrive dans le câble.

Dans la barre de filtre de Wireshark, tapez : [vlan.id](#) == 20.

Depuis le PCc (Baron), lancez un ping vers le ServWeb. Retournez sur Wireshark, vous devez être capable d'intercepter les paquets ICMP. Cliquez sur un de ces paquets et analysez-le.

Question : Dans la trame, qu'est-ce qui prouve qu'il s'agit bien d'un paquet intercepté grâce au trunking ?

Question : Ou se trouve l'élément qui indique qu'il s'agit bien du VLAN 20 qu'on écoute ?

Question : Si l'on peut voir un ping, quel autre type de trame peut on intercepter qui est plus confidentiel ?

Réponse : C'est la présence de la couche **802.1Q Virtual LAN** dans l'en-tête Ethernet.

Réponse : Dans les détails du paquet Wireshark, il faut dérouler la section "**802.1Q Virtual LAN**". À l'intérieur, on trouve le champ "**ID**" ou "**VLAN Identifier**". Si l'attaque a réussi, cet élément affichera précisément la valeur **20**. C'est le "blason" numérique qui confirme que la trame appartient aux nobles

Réponse : Le ping (ICMP) n'est qu'un signal sonore. En mode Trunk, on peut intercepter :

- **Des requêtes HTTP :** Pour lire des pages web ou capturer des formulaires de connexion non chiffrés.
- **Des flux Telnet ou FTP :** Pour voler des identifiants et des mots de passe qui circulent en clair.
- **Des requêtes DNS :** Pour savoir quels sites ou serveurs les gardes du VLAN 20 consultent.

III.3.3 - Résolution n°1 : Verrouiller les Portes (PosteOuest-SWA)

La vulnérabilité reposait sur le fait que le port était “polyvalent” (Dynamic). La résolution consiste à supprimer cette ambiguïté.

Manipulation : Forcer le mode access

Par défaut, un port peut hésiter entre devenir une simple porte de villageois ou un grand pont-levis. On force ici le garde à ne reconnaître que les villageois du VLAN 10.

Sur PosteOuest-SWA :

```
PosteOuest-SWA(config)# interface Ethernet0/3
PosteOuest-SWA(config-if)# switchport mode access
PosteOuest-SWA(config-if)# switchport access vlan 10
```

Le commutateur désactive la capacité du port à monter un Trunk, même si la Kali envoie des demandes insistantes.

Manipulation : Imposer le silence radio (no negotiate)

Même en mode access, le switch continue d'envoyer des paquets DTP toutes les 30 secondes pour annoncer son état. C'est une signature que l'espion peut utiliser pour identifier le matériel. On souhaite le désactiver ici.

```
PosteOuest-SWA(config-if)# switchport nonegotiate
```

Cette commande coupe totalement l'émission de trames DTP sur l'interface.

Question : Vérifier que les paquets DTP disparaissent sur Wireshark

III.3.4 - Etat des lieux : la ruse du Double Étiquetage

Même avec les portes verrouillées en mode access, un espion situé dans le VLAN Natif (le VLAN 1, utilisé par défaut pour la gestion du château) peut tenter une attaque par Double Tagging. Cette faille exploite le mécanisme de retrait automatique du blason natif lors du passage d'un Trunk.

Le Chevalier Noir a été bouté hors du mode Trunk par le Maître Architecte. Cependant, une faille subsiste : la confusion des blasons sur les ponts-levis (liens Trunks). Si l'espion parvient à se brancher sur une porte appartenant au VLAN Natif (le VLAN 1, celui qui n'est jamais étiqueté par les gardes), il peut tenter la manœuvre du Passager Clandestin.

Manipulation préliminaire : Le déplacement de l'espion

Pour que cette ruse fonctionne, le Chevalier Noir doit quitter le quartier des Villageois(VLAN 10).

Sur GNS3 : Déplacez le câble de la Kali du port Eth0/3 vers un port non configuré (par défaut dans le VLAN 1), par exemple sur le port Eth2/0 sur le PosteOuest-SWA.

Question : Quelle commande utilisez-vous sur le PosteOuest-SWA pour vérifier que le port Eth2/0 est assigné au VLAN 1 ?

Réponse : `sh ip int brief`

III.3.5 - Attaque n°2 : Le double Tagging (Double étiquetage)

Manipulation : Préparer la forge des paquets

Toujours dans Yersinia, passez sur l'onglet protocole 802.1Q (touche F3 normalement).

Appuyez sur “e” pour pouvoir modifier l'étiquette qu'on va envoyer.

```
802.1Q Fields
Source MAC 0E:5C:49:19:4A:94 Destination MAC FF:FF:FF:FF:FF:FF
VLAN 0001 Priority 07 CFI 00 L2Proto1 0800 VLAN2 0020 Priority 07 CFI 00
L2Proto2 0800 Src IP 010.000.000.001 Dst IP 255.255.255.255 IP Prot 01
Payload YERSINIA
```

Renseignez le VLAN natif (on laisse VLAN 1 car c'est le VLAN Natif par défaut) et le VLAN d'arriver (on va s'attaquer au VLAN 2).

Ne pas toucher aux autres champs.

Faites échap pour enregistrer les modifications.

Appuyez sur “x” pour accéder à la tables des attaques et sélectionnez “sending 802.1Q double enc. packet” en appuyant sur 1.

VLAN	L2Proto1	Src IP	Dst IP	IP Prot	Iface	Last seen
0001	802.1Q	10.0.0.1	255.255.255.255	icmp	eth0	20 Mar 14:01:30

Question : Que vient de faire la Kali exactement ?

Réponse : Elle a envoyé une trame ICMP (Ping) enveloppée dans deux couches : une première couche pour le VLAN 1 et une seconde pour le VLAN 20.

III.3.6 - Vérification de la réception du message

C'est ici que nous vérifions si le Passager Clandestin a franchi les murs.

Manipulation : Vérification de la réception du message

Lancez une capture Wireshark **entre** :

- La kali **et** le PosteOuest-SWA
- Le PosteOuest-SWA **et** le PosteEst-SWB
- Le PosteEST-SWB **et** le ServWeb

Refaire la manipulation précédente pour renvoyer une trame ICMP depuis la Kali.

Question : Qu'est-ce qui disparaît quand le paquet ICMP traverse le premier poste, puis le deuxième poste ?

Question : Pourquoi ne voit-on pas de réponse ("Pong") dans Wireshark ?

Réponse : Passage du premier poste (Switch Ouest) :

- Ce qui disparaît : La première étiquette (VLAN 1).

Passage du deuxième poste (Switch Haute-Cour / Switch Est) :

- Ce qui disparaît : La deuxième étiquette (VLAN 20).

Réponse : L'attaque est unidirectionnelle. Le serveur reçoit le message et tente de répondre au VLAN 20. Mais comme la Kali est physiquement sur un port du VLAN 1, le chemin de retour est rompu. Le Chevalier Noir a lancé une flèche, mais ne peut pas recevoir de lettre en retour.

III.3.7 - Résolution n°2 : Sécuriser les Traditions (Native VLAN)

Pour rendre cette ruse inopérante, l'Architecte doit s'assurer que le VLAN Natif ne correspond à aucun quartier habité.

Manipulation : Changer le VLAN Natif

Sur tous les liens Trunks entre les switches, déplacez le VLAN natif vers un ID inutilisé (VLAN 99)

```
PosteOuest-SWA(config)# interface Ethernet0/0
```

```
PosteOuest-SWA(config-if)# switchport trunk native vlan 99
```

Désormais, si la Kali envoie un double tag (1 et 20), le premier switch voit le tag 1. Comme 1 n'est plus le VLAN natif (c'est le 99), il ne retire pas le tag. La trame arrive au switch suivant avec deux tags, est jugée corrompue ou reste dans le VLAN 1, et finit dans les oubliettes. Le saut vers le VLAN 20 est bloqué.

III.4 - Attaque n°2 : DHCP Spoofing

III.4.1 - État des lieux

On observe les coutumes du royaume pour l'attribution des terres. Lorsqu'un nouveau Villageois (client) arrive, il crie à la cantonade (diffusion d'un message DHCP DISCOVER) pour réclamer un lopin de terre (une adresse IP). La règle est simple : le premier Intendant (serveur) qui lui répond est celui qu'il choisira. L'objectif du Chevalier Noir est double : d'abord, envoyer une horde de requêtes fantômes pour épuiser les réserves de terres du véritable Donjon (DHCP Starvation), puis installer un faux campement d'Intendant (Rogue DHCP) pour récupérer les vrais Villageois démunis.

III.4.1 - Attaque n°2 : DHCP Spoofing (Usurpation DHCP)

Manipulation 1 : Forger l'arme de siège (Yersinia).

Sur les terres du Chevalier Noir (Kali), préparer la redoutable machine de guerre capable de corrompre les protocoles. Ouvrez un terminal et invoquez :

```
sudo apt install yersinia
```

Manipulation 2 : L'assaut de la Famine (DHCP Starvation).

Utiliser Yersinia pour simuler une armée de milliers de faux paysans réclamant des terres. Le vrai routeur va distribuer toutes ses adresses IP jusqu'à épuisement total de son pool d'adresses.

Manipulation 3 : Le Faux Campement (dnsmasq).

Une fois le vrai Donjon à court de terre, lancer votre usurpateur dans un autre terminal. Ajoutez l'enchantement --no-ping pour sauter les vérifications de routine et répondre encore plus vite :

```
sudo dnsmasq -d -i eth0 --no-ping --dhcp-range=192.168.10.100,192.168.10.150,12h
```

Manipulation 4 : Le Piège se referme.

Sur les terres du pauvre Villageois (Debian), forcer une nouvelle demande de terres (via la commande `sudo dhclient eth0`). Le Donjon étant "affamé" (sans adresses disponibles), le Villageois n'aura d'autre choix que d'accepter l'offre empoisonnée du Chevalier Noir.

III.4.1 - Contrer le DHCP Spoofing et la Famine

Manipulation 1 : Les Sceaux de Confiance. Activer la vigilance de la garde royale sur le commutateur en tapant l'incantation de protection `<ip dhcp snooping>` pour filtrer les annonces des faux intendants.

Manipulation 2 : Protéger le véritable chemin. Définir les portes d'accès "de confiance" (trust) qui mènent exclusivement vers le véritable Donjon. (`ip dhcp snooping trust`)

Manipulation 3 : Bloquer l'Usurpateur. S'assurer que les autres portes (les ports non fiables menant aux simples utilisateurs) bloquent systématiquement les offres de terres illégitimes (messages DHCP Offer). (`ip dhcp snooping vlan 10,20`)

Manipulation 4 : Limiter la foule (Port-Security). (*Optionnel mais recommandé pour la famine*) Activer le switchport port-security pour limiter le nombre de visages (adresses MAC) autorisés par porte, empêchant ainsi Yersinia d'envoyer sa horde de requêtes fantômes.

Question 1 : L'assaut de la Famine. Pendant que votre machine de siège Yersinia frappe les murailles, utilisez votre longue-vue magique (Wireshark) sur le Chevalier Noir (Kali). Fournissez un croquis (capture d'écran) au Maître Architecte montrant la horde de requêtes (paquets DHCP DISCOVER) générées pour épuiser les réserves du Donjon.

Question 2 : Le faux lopin de terre. Sur les terres du pauvre Villageois (la machine Debian), lancez l'incantation `ip` a après avoir forcé une nouvelle demande d'attribution de terres. Rappelez une gravure (capture d'écran) prouvant qu'il a bien reçu une adresse corrompue (issue du pool 192.168.10.100-150) provenant du faux campement de l'Intendant.

Question 3 : La preuve de l'usurpation. En scrutant attentivement les registres de voyage de la victime (lancez l'incantation `ip route` sur la Debian), comment pouvez-vous prouver techniquement que le Villageois a été trompé par l'illusion de l'attaquant ? (Indice : regardez attentivement l'adresse de la porte de sortie, c'est-à-dire la passerelle par défaut).

Question 4 : Le Sceau de Confiance. Rappelez dans vos écrits l'incantation exacte (la commande Cisco) que vous avez gravée sur le poste de garde (le commutateur) pour désigner la seule route de confiance menant au véritable Donjon, afin de bloquer les futures offres illégitimes.

III.5 - Attaque n°3 : ARP Spoofing (Empoisonnement des registres)

III.5.1 - État des lieux

On analyse les voies de communication du royaume pour préparer l'embuscade. Le protocole ARP, utilisé pour lier les adresses logiques aux adresses physiques, ne possède aucun mécanisme d'authentification. Le Chevalier Noir (Kali) est en position pour s'interposer entre le Villageois (Debian) et le Donjon (Routeur), prêt à mener une attaque de type Homme du Milieu (MITM).

III.5.2 - Attaque n°3 : ARP Spoofing

Manipulation 1 : Ordonner au Chevalier Noir de faire suivre discrètement les missives interceptées en activant le routage (`sudo sysctl -w net.ipv4.ip_forward=1`) afin de rester furtif et de ne pas couper la connexion internet de la victime (ce qui provoquerait un Déni de Service).

Manipulation 2 : Ouvrir un premier terminal et envoyer de faux messages au Villageois pour lui faire croire que le Chevalier Noir est le Donjon en tapant : `arp spoof -i eth0 -t <@IP_VICTIME> <@IP_GATEWAY>`.

Manipulation 3 : Ouvrir un second terminal en parallèle et envoyer de faux messages au Donjon pour lui faire croire que le Chevalier Noir est le Villageois en tapant : `arp spoof -i eth0 -t <@IP_GATEWAY> <@IP_VICTIME>`.

Manipulation 4 : Déployer la longue-vue magique (Wireshark) sur l'interface eth0 de la machine Kali pour lire en clair le trafic détourné (comme les requêtes ping).

III.5.3 - Résolution n°3 : Contrer l'Empoisonnement ARP

Manipulation 1 : Mettre en place la garde royale d'inspection sur les remparts (commutateurs) en activant le Dynamic ARP Inspection (DAI).

Manipulation 2 : Taper l'incantation `ip arp inspection` pour vérifier la légitimité des parchemins ARP.

Manipulation 3 : S'appuyer sur les registres de confiance du DHCP Snooping pour s'assurer que l'adresse IP annoncée correspond bien à l'adresse MAC et au port physique légitimes, bloquant ainsi les menteurs.

Question : L'examen des registres du Villageois. Sur les terres de la victime (la machine Debian), lancez l'incantation `ip neigh` (ou `arp -a`) pour ouvrir ses registres de correspondances. Fournissez un croquis (capture d'écran) du résultat au Maître Architecte.

Question : La preuve de la trahison. En scrutant attentivement ce registre corrompu (la table ARP), comment pouvez-vous prouver techniquement que l'esprit de la machine a bien été

empoisonné par l'illusion de l'attaquant ? (Indice : regardez attentivement les blasons physiques, c'est-à-dire les adresses MAC).

Question : Le butin du Chevalier Noir. Rapportez une gravure (capture d'écran) de votre longue-vue magique (Wireshark) opérant sur la machine Kali, prouvant à la cour que vous avez bel et bien intercepté les pigeons voyageurs (les paquets ICMP du ping) envoyés par le pauvre Villageois.

```
root@kali)-[~]
# systemctl -w net.ipv4.ip_forward=1
net.ipv4.ip_forward = 1
```

[illegible][illegible]

The image shows a Wireshark packet capture of an ICMP Redirect for host message. The packet list shows 27 packets, with the first 24 packets being ICMP Redirect for host messages. The packet details pane shows the structure of the ICMP Redirect for host message, including the destination address 192.168.10.2 and the original destination address 8.8.8.8. The packet bytes pane shows the raw data of the message.

No.	Time	Source	Destination	Protocol	Length	Info
97	137.282626865	192.168.10.1	192.168.10.2	ICMP	118	Redirect (Redirect for host)
210	203.252977929	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=0xe475, seq=1/256, ttl=64 (no re
211	203.253027326	192.168.10.1	192.168.10.2	ICMP	126	Redirect (Redirect for host)
212	203.253147977	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=0xe475, seq=1/256, ttl=63 (reply
213	203.269628158	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=0xe475, seq=1/256, ttl=126 (requ
214	203.269653948	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=0xe475, seq=1/256, ttl=125
216	204.255654440	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=0xe475, seq=2/512, ttl=64 (no re
217	204.255698478	192.168.10.1	192.168.10.2	ICMP	126	Redirect (Redirect for host)
218	204.255972497	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=0xe475, seq=2/512, ttl=63 (reply
219	204.298593383	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=0xe475, seq=2/512, ttl=126 (requ
220	204.298630187	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=0xe475, seq=2/512, ttl=125
223	205.256431423	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=0xe475, seq=3/768, ttl=64 (no re
224	205.256476230	192.168.10.1	192.168.10.2	ICMP	126	Redirect (Redirect for host)
225	205.256638071	192.168.10.2	8.8.8.8	ICMP	98	Echo (ping) request id=0xe475, seq=3/768, ttl=63 (reply
226	205.271784002	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=0xe475, seq=3/768, ttl=126 (requ
227	205.271808117	8.8.8.8	192.168.10.2	ICMP	98	Echo (ping) reply id=0xe475, seq=3/768, ttl=125

scan nmap depuis la kali pour trouver la debian :

```
(root@kali)-[~]  
# nmap 192.168.10.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-18 20:08 UTC  
Nmap scan report for 192.168.10.2  
Host is up (0.0025s latency).  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
MAC Address: 0C:91:74:BC:00:00 (Unknown)  
  
Nmap scan report for 192.168.10.254  
Host is up (0.0091s latency).  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE  
23/tcp    open  telnet  
MAC Address: C4:01:2B:BC:00:01 (Unknown)  
  
Nmap scan report for 192.168.10.1  
Host is up (0.000017s latency).  
All 1000 scanned ports on 192.168.10.1 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
  
Nmap done: 256 IP addresses (3 hosts up) scanned in 51.89 seconds
```

```
(root@kali)-[~]  
# dnsmasq -d -i eth0 --dhcp-range=192.168.10.100,192.168.10.150,12h --dhcp-option=3,192.168.10.1 --dhcp-option=6,192.168.10.1  
dnsmasq: started, version 2.91 cachesize 150  
dnsmasq: compile time options: IPv6 GNU-getopt DBus no-UBus i18n IDN2 DHCP DHCPv6 no-Lua TFTP conntrack ipset nftset auth DNSSEC loop-detect inotify dumpfi  
le  
dnsmasq-dhcp: DHCP, IP range 192.168.10.100 -- 192.168.10.150, lease time 12h  
dnsmasq: reading /etc/resolv.conf  
dnsmasq: using nameserver 8.8.8.8#53  
dnsmasq: read /etc/hosts - 9 names
```

Commande a tester pr optimiser le temps :

```
dnsmasq --dhcp-range=192.168.10.100,192.168.10.150,12h --dhcp-option=6,192.168.10.1  
--dhcp-option=3,192.168.10.1 --dhcp-lease-time=5 --dhcp-ack-delay=1 --dhcp-no-override
```

```
dnsmasq-dhcp: DHCPDISCOVER(eth0) 192.168.10.3 0c:91:74:bc:00:00  
dnsmasq-dhcp: DHCPOFFER(eth0) 192.168.10.133 0c:91:74:bc:00:00  
dnsmasq-dhcp: DHCPREQUEST(eth0) 192.168.10.133 0c:91:74:bc:00:00  
dnsmasq-dhcp: DHCPACK(eth0) 192.168.10.133 0c:91:74:bc:00:00 debian
```

```
debian@debian:~$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 0c:91:74:bc:00:00 brd ff:ff:ff:ff:ff:ff  
    altnam enp0s4  
    inet 192.168.10.133/24 brd 192.168.10.255 scope global dynamic ens4  
        valid_lft 43199sec preferred_lft 43199sec  
    inet6 fe80::e91:74ff:febc:0/64 scope link  
        valid_lft forever preferred_lft forever
```



```
(root@kali)~[~/yersinia]
# dnsmasq -d -i eth0 --no-ping --dhcp-range=192.168.10.100,192.168.10.150,12h --dhcp-option=3,192.168.10.50 --dhcp-option=6,192.168.10.50
dnsmasq: started, version 2.91 cachesize 150
dnsmasq: compile time options: IPv6 GNU-getopt DBus no-UBus i18n IDN2 DHCP DHCPv6 no-Lua TFTP conntrack ipset nftset auth DNSSEC loop-detect inotify dumpfile
dnsmasq-dhcp: DHCP, IP range 192.168.10.100 -- 192.168.10.150, lease time 12h
dnsmasq: reading /etc/resolv.conf
dnsmasq: using nameserver 8.8.8.8#53
dnsmasq: read /etc/hosts - 9 names
```

```
(root@kali)~[~/yersinia]
# yersinia dhcp -attack 1 -interface eth0
<*> Starting DOS attack sending DISCOVER packet ...
<*> Press any key to stop the attack <*>

MOTD: Do you have an ISL capable Cisco switch? Share it!! ;)
```

```
R1#sh ip dhcp binding
Bindings from all pools not associated with VRF:
IP address Client-ID/ Hardware address/ User name Lease expiration Type
192.168.10.1 010c.f275.0300.00 Mar 02 2002 12:23 AM Automatic
192.168.10.2 571b.1372.40ce Mar 01 2002 01:13 AM Automatic
192.168.10.3 85d2.7935.1cb0 Mar 01 2002 01:13 AM Automatic
192.168.10.4 a6bc.7c69.7dd1 Mar 01 2002 01:13 AM Automatic
192.168.10.5 9700.4a66.afe3 Mar 01 2002 01:13 AM Automatic
192.168.10.6 e9c2.1b6e.5b33 Mar 01 2002 01:13 AM Automatic
192.168.10.7 69ea.e568.60f9 Mar 01 2002 01:13 AM Automatic
192.168.10.8 fd64.a428.839f Mar 01 2002 01:13 AM Automatic
192.168.10.9 ac08.3d7c.d1b6 Mar 01 2002 01:13 AM Automatic
192.168.10.10 09d0.7356.6312 Mar 01 2002 01:13 AM Automatic
192.168.10.11 95a6.2759.862b Mar 01 2002 01:13 AM Automatic
192.168.10.12 6e1c.f12f.c7d3 Mar 01 2002 01:13 AM Automatic
192.168.10.13 a8ea.e147.f195 Mar 01 2002 01:13 AM Automatic
192.168.10.14 d3c6.3d57.2b4a Mar 01 2002 01:13 AM Automatic
192.168.10.15 f9a6.295b.6b3b Mar 01 2002 01:13 AM Automatic
192.168.10.16 76ae.e564.3622 Mar 01 2002 01:14 AM Automatic
192.168.10.17 d39c.4e34.cec9 Mar 01 2002 01:14 AM Automatic
192.168.10.18 76f0.5b21.586f Mar 01 2002 01:14 AM Automatic
192.168.10.19 ea79.6d35.1dad Mar 01 2002 01:14 AM Automatic
192.168.10.20 d540.3102.817a Mar 01 2002 01:14 AM Automatic
192.168.10.21 cc90.246a.be03 Mar 01 2002 01:14 AM Automatic
192.168.10.22 dcad.b156.367b Mar 01 2002 01:14 AM Automatic
192.168.10.23 1efd.2d38.d912 Mar 01 2002 01:14 AM Automatic
192.168.10.24 b91a.aa1d.ca05 Mar 01 2002 01:14 AM Automatic
192.168.10.25 abc9.bc70.c3ea Mar 01 2002 01:14 AM Automatic
192.168.10.26 2d18.cd32.4070 Mar 01 2002 01:14 AM Automatic
192.168.10.27 4916.e47c.9b34 Mar 01 2002 01:14 AM Automatic
```

```
(root@kali)~[~/yersinia]
# dnsmasq -d -i eth0 --no-ping --dhcp-range=192.168.10.100,192.168.10.150,12h --dhcp-option=3,192.168.10.50 --dhcp-option=6,192.168.10.50
dnsmasq: started, version 2.91 cachesize 150
dnsmasq: compile time options: IPv6 GNU-getopt DBus no-UBus i18n IDN2 DHCP DHCPv6 no-Lua TFTP conntrack ipset nftset auth DNSSEC loop-detect inotify dumpfile
dnsmasq-dhcp: DHCP, IP range 192.168.10.100 -- 192.168.10.150, lease time 12h
dnsmasq: reading /etc/resolv.conf
dnsmasq: using nameserver 8.8.8.8#53
dnsmasq: read /etc/hosts - 9 names
dnsmasq-dhcp: DHCPDISCOVER(eth0) 192.168.10.133 0c:91:74:bc:00:00
dnsmasq-dhcp: DHCPOFFER(eth0) 192.168.10.133 0c:91:74:bc:00:00
dnsmasq-dhcp: DHCPREQUEST(eth0) 192.168.10.133 0c:91:74:bc:00:00
dnsmasq-dhcp: DHCPACK(eth0) 192.168.10.133 0c:91:74:bc:00:00 debian
```

Félicitations, Architecte ! Vous avez su transformer une infrastructure vulnérable en une forteresse imprenable face aux ruses de la couche 2. Le Royaume R&T est désormais en sécurité sous votre protection.

IV. Désinstallation

La bataille est terminée, le calme revient sur le Royaume. En tant que Maître Architecte, votre dernière mission est d'effacer les traces des combats et de remettre les infrastructures dans leur état d'origine, prêtes à accueillir de nouveaux défenseurs.

Le protocole de démobilisation doit être scrupuleusement respecté pour valider votre victoire.

IV.1 - Purge des Grimoires (Réinitialisation des équipements)

Sur les Commutateurs (Switchs) : Supprimez le registre en effaçant le fichier de la table des VLANs :

```
# delete vlan.dat
```

Sur tous les Équipements (Routeur et Switch) : Effacez la configuration de la mémoire non-volatile (NVRAM) :

```
# write erase
```

(Pensez à redémarrer les équipements pour confirmer la remise à zéro).

```
# reload
```

IV.2 - Libération des Émissaires (Configuration des hôtes)

Les machines Debian et les postes de travail doivent oublier les ordres spécifiques reçus durant le siège.

Remettez toutes les cartes réseau des ordinateurs en mode DHCP automatique.

```
sudo vconfig rem eth0.20
```

```
sudo dhclient -r eth0 # -r pour release (libérer l'ancienne IP)
```

```
sudo dhclient eth0 # Demander une nouvelle IP au Scribe légitime
```

IV.3 - Inspection Royale (Validation par Sir Droussi)

Un château ne peut être quitté sans l'aval de Prince Abdallah et Sir Droussi.

Faites vérifier que toutes les configurations ont bien été effacées.